

Informe de Estado — SIZO (SG-SST ERP)

Fecha del informe: 06 de julio de 2026 **Elaborado para:** Webcore Solutions **Producto:** SIZO — ERP de Seguridad y Salud en el Trabajo (SG-SST)

1. Resumen ejecutivo

SIZO es un ERP SaaS multitenant para la gestión del Sistema de Gestión de Seguridad y Salud en el Trabajo (SG-SST), orientado al mercado colombiano y regulado por el Decreto 1072 de 2015. Es un producto propio de Webcore Solutions, sin cliente externo asociado. Actualmente está en producción en GitHub Pages, con 18 módulos operativos, autenticación multitenant vía Supabase Auth, seguridad reforzada (RLS + auditoría de seguridad H1-H15 resuelta) y un módulo de administración de plataforma (SUPERADMIN) recién incorporado.

El principal gap identificado es la ausencia de un flujo de **autoregistro público de tenants**: hoy cada cliente nuevo requiere provisión manual por parte de un superadmin (vía Edge Function crear-tenant), lo cual bloquea la escalabilidad comercial. El modelo de **billing/planes está implementado en código pero suspendido operativamente** por decisión del negocio — no se está cobrando ni restringiendo por plan en este momento.

2. Arquitectura y stack técnico

Capa	Tecnología
Frontend	HTML / CSS / JavaScript vanilla — SPA sin framework, ES modules
Enrutamiento	router.js — hash-based, carga de módulos dinámica
Estado	store.js — patrón get/set/subscribe sin dependencias externas
Autenticación	Supabase Auth — JWT con app_metadata (tenant_id, role, empresas_ids, superadmin)
Base de datos	Supabase PostgreSQL con Row Level Security (RLS) multitenant
Almacenamiento	Supabase Storage — bucket documentos (PDFs firmados)
PDF client-side	pdf-lib (UMD) + signature-pad (UMD), vendorizados localmente
Despliegue	GitHub Pages — CI/CD automático vía GitHub Actions al hacer push a main

Modelo de seguridad: la seguridad real recae en las políticas RLS de Postgres, no en el enrutador del frontend (que solo aplica gating de UX). Existen tres roles: ADMIN (acceso total al tenant), ASESOR (solo empresas asignadas, lectura/escritura) y CONSULTA (solo lectura).

3. Estado actual — Lo que se ha hecho

3.1 Módulos funcionales en producción (18)

Módulo	Función
Dashboard	Vista consolidada y vista individual por empresa
Seguimiento	Indicadores SG-SST por empresa y periodo
Empresas	CRUD + asignación de asesores
Usuarios	CRUD + creación de usuarios vía Edge Function (crear-usuario)
Accidentes	Registro y seguimiento de accidentalidad laboral
Ausentismo	Registro de ausentismo laboral
Acciones	Plan de acción / acciones correctivas
Inspecciones	Inspecciones de seguridad
Capacitación	Registro de capacitaciones SG-SST
Plan	Plan de trabajo anual SG-SST
Auditoría	Módulo de auditoría interna
Casos médicos	Solo visible para ADMIN (política RLS restrictiva)
Indicadores	Motor de cálculo desacoplado del DOM (calcular-indicadores.js), 20 KPIs, cálculo de HHT según Decreto 1072 Art. 2.2.4.1.7
Maestro	Catálogo maestro de 20 KPIs
Perfil	Gestión de perfil de usuario
Archivos	Gestión documental: subir, previsualizar, firmar (firma dibujada o imagen + notas incrustadas vía pdf-lib), descargar, soft-delete
SUPERADMIN	Panel de administración de plataforma — gestión de tenants (nuevo)

3.2 Seguridad

Se ejecutó una auditoría de seguridad completa el 15 de junio de 2026, identificando y resolviendo 15 hallazgos (H1–H15), incluyendo: - Protección contra XSS mediante escape sistemático de datos interpolados - Suite de pruebas de RLS autenticada por rol - Trigger de base de datos que impide auto-escalamiento de rol/tenant - Vendorización de dependencias externas (eliminación de CDN de terceros) - Content Security Policy (CSP) implementada - Límite de resultados por consulta (.limit(500)) - Refresco automático de sesión JWT al recuperar el foco del navegador - Optimización de políticas RLS (InitPlan) en 35 políticas / 14 tablas - Recuperación de contraseña - Corrección del cálculo de HHT en indicadores IFA/IFM/ISA

Estado de pruebas automatizadas: **24 PASS / 0 FAIL** (unitarias + mecánicas) y **7 PASS / 0 FAIL** (seguridad RLS).

3.3 Modelo de billing y plataforma (implementado, no activo)

En el último ciclo de desarrollo (commit da023a5, 2026-06-30) se incorporó: - Migración 005_billing.sql: columnas estado (trial/activo/suspendido) y empresas_limite en la tabla tenants; planes starter/pro/agencia; función is_superadmin(). - Módulo superadmin.js: gestión de tenants — cambio de plan, suspensión/reactivación, marcar como pagado, extensión de trial. - Validaciones de billing en el módulo Empresas: bloqueo por cuenta suspendida, trial vencido, o límite de plan alcanzado.

Importante: por decisión del negocio (2026-07-06), toda la lógica de billing/restricción de planes está **suspendida operativamente**. El código existe y está desplegado, pero no debe aplicar restricciones a los tenants mientras dure esta pausa.

3.4 Migraciones de base de datos aplicadas

Migración	Contenido
001_schema_inicial.sql	Schema base + funciones helper RLS
002_h3_proteger_usuarios.sql	Trigger de protección de columnas sensibles en usuarios
003_h10_optimizar_rls.sql	Optimización InitPlan de 35 políticas RLS
004_archivos.sql	Tabla archivos + bucket de almacenamiento documentos
005_billing.sql	Modelo de billing multitenant (ver 3.3)

3.5 Provisión de tenants (estado actual, pre-autoregistro)

Existe la Edge Function crear-tenant que permite crear un tenant y su usuario ADMIN asociado, pero **requiere invocación manual con credenciales de service role** — no es un flujo self-service para el cliente final.

4. Pendiente

#	Tarea	Estado	Prioridad
1	Verificar en producción las 3 validaciones de billing (suspendido / trial vencido / límite de plan)	En pausa por decisión de negocio — billing suspendido	Baja (mientras dure la pausa)
2	Banner de estado de plan/trial en topbar	No iniciado	Baja (mientras dure la pausa)
3	Autoregistro público de tenants (página #register, formulario, Edge Function registrar-tenant, verificación por email)	No iniciado	Alta — gap crítico que bloquea la escalabilidad comercial

#	Tarea	Estado	Prioridad
4	Encabezados de seguridad HTTP en Cloudflare (X-Frame-Options, X-Content-Type-Options, HSTS)	Pendiente — requiere dominio personalizado	Media
5	Dominio personalizado para el producto	Sin definir	Media
6	Ejecutar suite de tests + deploy tras completar autoregistro	No iniciado	Alta (depende de #3)

Nota: dado que el billing está suspendido, el flujo de autoregistro (ítem 3) debería replantearse para no depender de validaciones de plan mientras dure la pausa — los tenants nuevos podrían crearse directamente en estado "activo" sin restricciones, simplificando el alcance de esa Edge Function.

5. Matriz DOFA

Debilidades (interno, negativo)

- No existe autoregistro: cada cliente nuevo depende de intervención manual del equipo técnico, lo que introduce fricción y no escala.
- Ausencia de dominio propio y de headers de seguridad HTTP a nivel de CDN (dependen de Cloudflare + dominio personalizado, aún no configurados).
- Frontend sin framework: mantenible para un equipo pequeño hoy, pero puede volverse costoso de escalar si el producto crece en complejidad de UI.
- Migraciones de base de datos se aplican manualmente vía Supabase Dashboard — no hay pipeline automatizado de migraciones ni control de versiones ejecutado en CI/CD.
- Producto sin cliente externo validando el modelo comercial en curso — la validación de mercado depende de que se resuelva el autoregistro.

Oportunidades (externo, positivo)

- Mercado regulatorio cautivo: el Decreto 1072 de 2015 obliga a las empresas colombianas a mantener un SG-SST, generando demanda estructural y recurrente.
- El módulo SUPERADMIN y el modelo de billing ya están contruidos — una vez se decida reactivar el cobro, la infraestructura técnica está lista.
- Nicho desatendido de PyMEs y consultoras de SG-SST que hoy gestionan el cumplimiento en hojas de cálculo.
- Posibilidad de vender también a consultoras SG-SST como revendedoras (el rol ASESOR y el plan "agencia" ya contemplan multiempresa).

Fortalezas (interno, positivo)

- Arquitectura multitenant con seguridad real enforced a nivel de base de datos (RLS), no solo en el cliente — reduce el riesgo de fugas de datos entre tenants.
- Auditoría de seguridad completa ya ejecutada y resuelta (15/15 hallazgos), lo cual da una base sólida de confianza para un producto que maneja datos sensibles de salud y accidentalidad laboral.

- Cobertura funcional amplia: 18 módulos que cubren el ciclo completo del SG-SST (accidentes, ausentismo, capacitación, inspecciones, indicadores, documentación firmada).
- Motor de cálculo de indicadores desacoplado del DOM, facilitando pruebas y mantenimiento.
- Stack simple (vanilla JS + Supabase) alineado con el tamaño del equipo (7 personas), evitando sobre-ingeniería.
- Suite de pruebas automatizada (unitarias, mecánicas y de seguridad RLS) con 100% de éxito actual.
- Costo de infraestructura bajo: GitHub Pages + Supabase, sin servidores propios que mantener.

Amenazas (externo, negativo)

- Competencia de ERPs de SG-SST ya establecidos en Colombia con base de clientes existente.
- Dependencia de un único proveedor de backend (Supabase) para autenticación, base de datos y almacenamiento — riesgo de vendor lock-in.
- Cambios regulatorios en la normativa SG-SST podrían requerir adaptaciones no planificadas al motor de indicadores.
- Sin dominio propio ni headers de seguridad HTTP completos, la percepción de seriedad/confianza ante clientes corporativos puede verse afectada.
- Manejo de datos sensibles (salud, accidentalidad) implica exposición legal/reputacional alta ante cualquier incidente de seguridad, pese a las mitigaciones ya implementadas.

6. Conclusión

SIZO cuenta con una base técnica sólida: cobertura funcional completa del SG-SST, seguridad auditada y resuelta, y la infraestructura de billing/administración ya construida para cuando el negocio decida activarla. El cuello de botella actual no es técnico en el sentido de calidad del código, sino de **flujo comercial**: sin autoregistro, el crecimiento de la base de clientes depende de trabajo manual del equipo. Resolver el ítem de autoregistro (simplificado, sin restricciones de plan mientras el billing esté en pausa) es la palanca de mayor impacto para desbloquear la siguiente etapa del producto.